EgoQuant: Limitations and Roadmap

Status: 20 October 2026. This document says what EgoQuant does not do, where it is weak, what we measured about it, and what we would do next. We list these openly on purpose: the security design of EgoQuant rests on honest edges, and a limit that is written down can be defended. The security-specific list with owners is `docs/SECURITY.md` *section 4; this document covers everything else as well.*

1. What EgoQuant is, and is not

It is	It is not
A **competition prototype** of a wealth-advisory agent: a profile, a portfolio proposal inside hard limits, a report, an explaining assistant and a tamper-evident record.	A **licensed or regulated advice service**. Nobody should invest real money on the strength of it.
Advice only: every output is a proposal or an explanation.	An **execution venue**: it places no order, holds no money, and has no way to. The broker link is read-only.
Built on **real historical prices** (a saved snapshot to 16 Oct 2026 and live feeds when allowed), with invented demo investors.	A **forecasting tool**: nothing it shows predicts a price or a return.
English in the pages and the report; the assistant answers in the language it is asked in.	A **Chinese-language product** yet (roadmap).
One investor, one goal, one portfolio at a time.	A household, tax-aware or multi-goal planner. No tax, no fees beyond fund expense ratios and an assumed trading cost, no currency risk modelling beyond what the price history contains.

2. Limits of the method (and what we measured)

2.1 The category limits are placeholders

The numeric limits behind C1 to C5 (maximum stocks, volatility, loss in a named stress scenario, caps on commodities, crypto and cash, the product risk level) are our own **provisional** values. Every report carries a visible banner saying so. A real institution would replace them with its own approved table; the code reads them from one place (`egoquant/models.py` `RiskClassPolicy`, `egoquant/risk_profile/config.yaml`). **Nothing in EgoQuant has been reviewed by a compliance officer or a regulator.**

2.2 The questionnaire and the Risk Game are self-reported

- The questionnaire uses validated instruments (Grable and Lytton's risk-attitude scale, Lusardi and Mitchell's financial-literacy questions), but the cut-off points that turn a score into a level are our design and are documented with their reasons (`egoquant/risk_profile/README.md`), not calibrated on a population.
- The **Risk Game** is a short hypothetical game. We have **no psychometric validation** of it (no reliability or validity study), and the weight we give it (one third of the attitude to risk) is a product decision. Its effect is bounded: it can move the attitude by at most a third of the distance to its level, never past the capacity cap, and "I could not accept any loss" always gives the most careful category. The result is client-reported and can be replayed until a wanted category appears (bounded by one step). Kill switches exist for both its weight and its power to raise (`docs/RISK_GAME_BLEND.md`).
- The capacity side averages four answers (horizon, months of savings outside the investment, its share of total wealth, income stability) and treats two things as hard caps (money that must come back; a

horizon under three years). Averaging is a deliberate choice so that one answer, for example an irregular income, does not decide everything; the downside is that a very strong answer elsewhere can offset a weak one except where a hard cap applies.

2.3 The goal simulation is a simulation of the past, not a probability

- The chance of reaching a goal is shown as "N in 100 simulated futures" and is built from about 19 years of real daily prices (`egoquant/agents/quant/goal.py`). Nineteen years contain a small number of independent market cycles.
- We correct two known biases (bond and cash returns are set to today's rates; stocks get the average their market sensitivity earned, not their lucky past) and use a regime-aware sampler. **Our own calibration backtest** (rolling start dates, models refitted on earlier data only, `eval/results/regime_v2_summary.md`) shows that the new sampler scores better than the plain bootstrap over all dates (Brier score lower by 0.007 at five years and 0.011 at ten years, intervals above zero), **but on the later confirmation dates the gain is within the noise**.
- The table in that file also shows that **the simulated chance is only a rough guide**: for some portfolio types the share of past start dates that actually reached the goal differs from the average predicted chance by tens of percentage points (for example 90% reached against 45% predicted for a 90%-stocks portfolio, and 18% reached against 47% predicted for a bond-only portfolio). The roughly 19 years of history contain the 2008 crisis, a long bull market and the 2022 rate shock, but few independent cycles. This is why the report says "simulated", never "probable", and why the Goal tab shows how much the answer depends on which half of history is used.
- The simulation ignores: taxes, withdrawals other than the planned flow, inflation beyond what is in the prices, changes in the investor's life, and any regime that is not in the history.
- **The numbers can differ a little between computers.** The portfolio search can end on a slightly different but equally valid answer when the computer's math libraries use a different number of threads or another processor, so a re-run of the demo pack (`eval/demo_pack.py`) may show a mix a couple of points apart or near-equal holdings in another order (more for the optional method v2: on one development PC the balanced investor's bonds moved from 60% to 38% between two thread settings). In our test the goal chance of the default method moved by 0 points and that of the optional method v2 by up to 6 points; the verdicts and the checks are run on whatever portfolio is built. The documents say "can move by a few points" for this reason.

2.4 Prices and data

- The committed snapshot (292 tickers) comes from **Yahoo Finance** and is accepted by the team **for the competition only**; a commercial product would need a licensed feed. Live feeds (Tiingo, Binance) need keys and were slow from the host (a build with 20 interest areas took about 195 s on 19 Oct, roughly 15 s per live price request; `eval/slow_feed_drill.py`), so the competition setting uses the snapshot (`EGOQUANT_PRICE_MODE=snapshot`) and every report says which prices it used and until which day.
- Single stocks come from today's most-traded list (survivorship and look-ahead bias); the hindsight correction addresses the average return but not the fact that failed companies are absent.
- When the network or a feed fails the system falls back to saved prices and **says so**; on invented (synthetic) prices the market-phase (regime) sampler is not used: the plain block bootstrap runs and the report records which sampler ran and why.

2.5 Behaviour (Agent B)

- Agent B reads an IBKR Flex report. A person with few trades gives weak evidence; below a confidence threshold the evidence is ignored, and it can only tighten limits, never loosen them.

- Only IBKR is supported (report upload or a one-off Flex token). Binance and other brokers are roadmap.

2.6 News (Agent D) and the one AI exception

- The tone label for a headline and a named fund comes from an LLM with a hash-pinned prompt: **85% agreement with our hand labels on 120 headlines (FinBERT: 53%)**. That is a small test set and our own labelling. The label never sets a number the person acts on; it only feeds the News tab and an alert that *offers* a profile re-check (`docs/AGENT_D_LIMITATIONS.md`).

3. Limits of the AI assistant

- It explains; it does not decide. But an LLM can still **mis-explain** in words. Number grounding blocks wrong numbers, not wrong sentences. The compliance guard is pattern-based (36 patterns, English and Chinese) and cannot catch every phrasing.
- The assistant's prompt has changed four times in the last day (trade questions, report-tab awareness, a compliance review, and the trade tool's size field after the live red-team of 20 Oct). **That live red-team found a real defect in advisor-v10** (the model filled both size fields of the trade tool, so no trade check completed; a safe failure) **and the fix, advisor-v11, passed 41 of 42 cases** (the one miss is a false positive of the keyword check); trade-explain-v4 passed 51 of 51; earlier versions passed the live runs kept in `eval/results/` (advisor chat, prompts v2 to v5: 19/19, 19/19, 21/21 and 24/24; trade explanation: 22/24 then 24/24, 24/24 and 51/51 twice); a regime-wording check run on 19 Oct was not kept.
- It depends on an external provider; when that is down or out of credit the report, limits, trade checks and what-if numbers still work and the chat says so in one sentence.
- Each chat message is a paid call to the provider; there is a per-minute rate limit but no per-user budget.

4. Limits of the security and privacy design

The full list with owners is `docs/SECURITY.md` section 4 (28 items). The ones a reviewer should know first: 1. **Account features are proven at table level on the real Supabase project (19 Oct)**; a team member walked the seal path on the live site on 20 Oct (build, confirm and seal, download, verify, tamper: Sepolia block 11,954,258); the two-user smoke test through the deployed backend is still to be recorded. 2. **E-mail confirmation uses Supabase's small shared sender** and its confirmation link cannot be edited on the free plan: a new user may need a second attempt, and a crowd of judges signing up at once could exhaust the quota. A ready demo account and/or a custom SMTP sender are the planned answers. 3. **Rate limits and the concurrency gate are per process**, not per IP. A heavy build alone peaks at about 300 to 415 MB (10 years) and up to 875 MB (30 years) on our development PC (we did not measure the live 1 GB service), and each extra simultaneous build adds about 150 MB, so one portfolio is built at a time per server process (default 1, `EGOQUANT_MAX_CONCURRENT_BUILDS` , a provisional setting); the others wait their turn. Through the website the wait ends after 115 s with the website's own "too slow" answer; a direct API call gets, after 120 s, a 503 "The service is busy building other portfolios" with Retry-After 30. When many people press Build at the same moment, some will be told to try again; ordinary builds (5 to 7 seconds) were not flood-tested. 4. **A public blockchain entry cannot be deleted.** Mitigated by the salt (the fingerprint reveals nothing without the record, and "delete my data" deletes both, so we can no longer link it to a person; a person who kept a downloaded sealed report still can). The chain is a **test network** (Sepolia): it makes no promise to keep its entries forever (a test network can be reset or retired), so lasting permanence would come from the consortium chain a real deployment would use. The Verify page runs code our own website serves; the command-line verifier (`python -m egoquant.anchoring verify`) is the check

that does not depend on it. 5. **The frontend's content-security policy allows inline scripts** (a Next.js requirement); a per-request nonce is the planned replacement. `operation_log` is an activity record, not a tamper-proof audit log. 6. **No penetration test by a third party.** Our evidence is our own: about 3,500 automatic tests, hostile-input suites, property sweeps, mutation checks, live red-teams and read-only probes against the deployed system. 7. **The old Tiingo key is in the git history** (private repository) and is to be rotated.

5. Operations

- **Hosting is on free or trial plans:** the backend runs on a Railway service with 1 GB of memory and 2 vCPU on a trial plan (limited credit), the frontend on Vercel (upgraded from the free Hobby plan to Pro on 20 Oct, after the free plan's daily deployment limit was reached; the public URL changes only when a Ready build is promoted by the project owner). A real service would use paid plans with an automated release pipeline.
- One backend process on a small Railway service; the first request after a redeploy is slower; there is **no monitoring or alerting** beyond the host's logs, and no automated deployment pipeline with tests (a human runs the tests and a read-only `eval/deploy_check.py` after each deploy).
- **Test infrastructure:** the offline suite is run on Windows. With the newest numerical stack there (Python 3.13, pandas 3.0, numpy 2.5) a test process sometimes dies natively when many threads are created or many pandas operations run at once; a 12-thread pandas script that uses none of our code crashed in 4 of 18 runs (0 of 9 on pandas 2.3 and numpy 2.2). We contain it (one math thread per process, a build gate of one slot, a per-file retry runner for the suite) and publish the live library versions in `/data/status`; we have not been able to attribute it (it reproduces with a short pandas script that uses none of our code, but we could not test on Linux, which is what the host runs), and so far we have only seen it as a dead or stalled process.
- **Known edge cases:** a C3 to C5 investor with a cash need of 50% or more gets no portfolio (the report says so in plain words); goal builds with long horizons are the heaviest requests (the goal simulation keeps every candidate's path array; up to about 875 MB for a 30-year goal on our development PC, not measured on the live service), which the build gate bounds.
- **Dependencies are pinned:** `requirements.txt` pins all 56 packages to exact versions (the numerical libraries since 20 Oct, to the versions we tested, which were also the newest on PyPI: numpy 2.5.4, pandas 3.0.6, scipy 1.18.1, requests 2.34.2); the live versions are shown in `/data/status` (`libraries`) and match. A release would add a lock file with hashes.
- Supabase free plan: no point-in-time recovery; retention is 180 days by design (`purge_expired()` daily).
- The repository history contains the team's work-in-progress notes; the judged state is the tagged freeze.

6. Roadmap: what we would do next, in order

1. **Institutional calibration.** Replace the provisional category table with a bank's approved mapping; add a periodic suitability review (profile validity and re-check triggers already exist: Agent D can offer a re-check).
2. **Validate the Risk Game** with a real sample (reliability, test-retest, relation to the questionnaire) before raising its weight, and make the result of record non-replayable.
3. **Licensed market data** and a full price history store; remove the snapshot's licence limit; add FX and tax awareness.
4. **Consortium chain.** Move the same salted fingerprint format from Sepolia to FISCO BCOS (the format is chain-agnostic); add an authority that countersigns seals.

5. **More brokers and Chinese-language advice**, including a Chinese UI and a Chinese-reviewed compliance guard.
6. **Decide portfolio method v2** (risk parity, hierarchical risk parity, Black-Litterman, resampling; built and tested, off by default) after a time-budget and goal-chance review (`docs/V2_DECISION_SHEET.md`).
7. **Assurance.** Third-party penetration test and privacy impact assessment; continuous integration with the offline suite and the deploy check; monitoring and alerting; a per-user spending cap for the AI.
8. **Accessibility audit** against WCAG 2.2 AA with real assistive-technology users.

7. What we deliberately did not build

- **Order execution or anything that moves money.** It would be the largest risk surface and is not needed to demonstrate suitability, explanation and traceability.
- **Return forecasts, price targets or "buy" signals.** The assistant is built and tested not to produce them.
- **Storing broker credentials, chat transcripts or uploaded files.**
- **Hidden defaults.** Limits, sources, model versions and caveats are shown in the report; kill switches are documented in `docs/DEPLOY_ENV.md`.